



Lab 3 — Analyse the Lethal Trifecta in a Live Agent Design

Topic 01: AI Security Governance Foundations and Business Risks

Objective: Analyse an agentic AI design, identify the lethal-trifecta exposure and the applicable NIST GenAI risks, and propose an architectural break.

Goal: NovaBank's digital team has proposed 'NovaAssist', a customer-service agent that reads the customer's account, searches incoming e-mail and web content for context, and can send e-mails and raise payment instructions. You will analyse the design against the lethal trifecta and the NIST AI 600-1 GenAI risk set, and recommend a redesign.

What you'll build: A completed agent risk analysis: the trifecta assessment, five mapped NIST GenAI risks, a documented attack path and a redesign that breaks the trifecta.

Tools and data: NovaAssist design brief (novassist-design-brief.md), NIST AI 600-1 risk list, trifecta worksheet

Data files in this lab

- data/novassist-design-brief.md
- data/trifecta-worksheet.md

Step-by-step

1. Read novassist-design-brief.md in labs/lab-03-lethal-trifecta/data/. List every data source the agent reads and every action it can take.
2. Test the design against leg 1 — access to private data. Record exactly which confidential or personal data the agent can reach, and under whose permissions it reads them.
3. Test leg 2 — exposure to untrusted content. Identify every input the agent ingests that an outsider can influence: customer e-mail, web pages, uploaded documents, third-party API responses.
4. Test leg 3 — ability to communicate externally. List every outbound channel: sending e-mail, calling external APIs, writing to shared systems, even rendering links that auto-fetch.
5. Write the attack path in five steps: how an attacker gets untrusted text in front of the agent, how that text redirects the agent's goal, and how data leaves the bank. Base it on the EchoLeak pattern.

6. Map the design against the NIST AI 600-1 GenAI risk set and select the five most relevant: Information Security, Data Privacy, Information Integrity, Human-AI Configuration and Value Chain and Component Integration.
7. For each of the five risks, write one sentence of business impact specific to a Singapore retail bank, including the PDPA exposure where personal data is involved.
8. Propose the architectural break. Choose which leg of the trifecta to remove and justify it — for example, splitting the agent so the tool that reads untrusted content has no outbound channel and no access to account data.
9. Record the residual risk after your redesign, and name the one control you would still add on top of the architecture.

Test it

You can state which of the three legs your redesign removes and why removing that leg is more effective than adding an output filter to the original design. Your five NIST risks are each tied to a concrete NovaBank consequence, not a generic description.

Training use only. The organisation, data and individuals in this lab are fictional. Security techniques taught here must only be applied to systems you own or have written authorisation to test.